MCP Apps: تقييم حدود الثقة في دراسة تجريبية للقدرات التي يديرها المضيف

مقترح بحثي

جامعة الإمارات الدولية

أ.د. ب. مالك ناصر علي الجبري؛ مبارك وليد الحمادي؛ ياسين عبد العزيز الخالقي؛ محمد سيف علي الحيمي

2026 / 8

ملخص

يسمح امتداد MCP Apps لخادم MCP بتقديم واجهات تفاعلية يعرضها المضيف داخل بيئة معزولة. يحمي هذا العزل الواجهة من المضيف، لكن الواجهة تظل قادرة على طلب قدرات يديرها المضيف مثل فتح رابط أو إرسال رسالة محادثة أو تحديث سياق النموذج. لذلك لا تقتصر الحماية على العزل، بل تعتمد أيضًا على قرارات السياسات التي يطبقها المضيف على هذه الطلبات (Salomon et al., 2026). يقدم هذا المقترح دراسة تجريبية قابلة للتكرار لحدود الفصل بين ما يمنعه العزل تقنيًا وما يجب أن يضبطه المضيف بسياساته. نقارن بين مضيف ملتزم بالمواصفة (خط الأساس) وبين المضيف نفسه بعد إضافة طبقة سياسة صغيرة على جانب المضيف (المعالجة)، مع قياس الأمن واستمرار الوظائف المشروعة وزمن المعالجة. ونصوغ ثلاث فرضيات قابلة للاختبار ونوضح نطاق إثبات الفكرة بصدق.

1. المقدمة

يسمح بروتوكول Model Context Protocol (MCP) لتطبيقات الذكاء الاصطناعي بالتعامل مع أدوات وموارد خارجية بطريقة موحدة. ويضيف امتداد MCP Apps خادم MCP واجهات تفاعلية يقدمها المضيف داخل بيئة معزولة، بدل الاكتفاء بإرجاع النصوص والبيانات ويعرضها (Hou et al., 2025; Model Context Protocol, 2026b).

المضيف من الوصول المباشر إلى صفحته وبياناته، لكن واجهة sandbox يحمي الـ MCP App تستطيع طلب قدرات ينفذها المضيف، مثل فتح رابط، أو إرسال رسالة إلى المحادثة، أو تحديث سياق النموذج. لذلك لا تقتصر الحماية على العزل، بل تعتمد أيضًا على القرارات والسياسات التي يطبقها المضيف على هذه الطلبات (Salomon et al., 2026).

تنبع أهمية الدراسة من أنها تركز على الحد الفاصل بين ما يمنعه العزل تقنيًا وما يجب أن يضبطه المضيف بسياساته. وستقدم الدراسة اختبارًا عمليًا لهذا الحد، ثم تقارن بين مضيف ملتزم بالمواصفة والمضيف نفسه بعد إضافة طبقة سياسة محددة؛ بما يساعد على تقليل المخاطر مع المحافظة على الوظائف المشروعة.

2. الدراسات السابقة

ركزت دراسات أمن MCP على مخاطر الخوادم والأدوات، وإدارة الصلاحيات، وحقن الأوامر غير المباشر. وأظهرت أن اتصال النماذج بالأدوات قد يؤدي إلى تنفيذ غير مرغوب أو كشف بيانات إذا لم تضبط الثقة والصلاحيات (Hou et al., 2025; Maloyan & Namiot, 2026; Radosevich & Halloran, 2025). كما قدمت أعمال AgentBound وAgentDojo أساليب اختبار أمن وفرض حدود التنفيذ، لكنها لم تركز على رسائل واجهة MCP App إلى المضيف (Bühler et al., 2026; Debenedetti et al., 2024).

أما مواصفة MCP Apps وSEP-1865 فتحددان العزل و CSP ورؤية الأدوات والقنوات التي يديرها المضيف، لكنهما تقدمان متطلبات تصميم لا مقارنة تجريبية لطبقة تشديد إضافية (Model Context Protocol, 2026b; Salomon et al., 2026).

2.1 مقارنة مختصرة للأعمال السابقة

الباحثون / السنة	العنوان	المميزات	العيوب والفجوات
Model Context Protocol: Salomon et al. (2026)	مواصفة MCP Apps وSEP-1865	تحدد البنية الرسمية ونموذج التهديد ورؤية CSP) والضوابط	لا تقدمان مقارنة تجريبية قبل سياسة مضيف إضافية

		الأدوات والقنوات).	وبعدها.
Maloyan & Namiot (2026)	Breaking the Protocol	تحليل للمواصفة وتجارب على الحقن والثقة.	يركز على MCP الأساسي لا القنوات التفاعلية.
Bühler et al. (2026)	AgentBound	يفرض سياسات على تنفيذ خوادم MCP.	يعالج مستوى النظام لا رسائل الواجهة.
Hou et al. (2025)	MCP: Landscape, Security Threats, and Future Research Directions	تصنيف واسع لمخاطر MCP ودورة حياة الخادم.	لا يركز على واجهات MCP Apps وقرارات المضيف.
Radosevich & Halloran (2025)	MCP Safety Audit	تدقيق عملي لمخاطر خوادم MCP وأدوات.	لا يختبر الحد بين واجهة MCP App والمضيف.
Debenedetti et al. (2024)	AgentDojo	يقيس الأمن مع الحفاظ على العمل المشروع.	بيئة عامة للوكلاء وليست لمضيف MCP Apps.
Greshake et al. (2023)	Not What You've Signed Up For	يوضح خطر حقن الأوامر غير المباشر.	ليس مخصصًا لـ MCP Apps.

2.2 الفجوة البحثية

في حدود المصادر التي راجعناها، ركزت الدراسات السابقة على أمن خوادم وأدوات MCP، أو حقن الأوامر وعزل الوكلاء. ولم نجد دراسة تجريبية مركزة تقارن بين مضيف MCP Apps ملتزم بالمواصفة والمضيف نفسه بعد تفعيل سياسة إضافية للتحكم في القدرات التي يديرها المضيف، مع قياس الأمن والحفاظ على الوظائف والأداء. يعالج البحث هذه الفجوة ببناء بيئة اختبار قابلة للتكرار ونموذج أولي صغير لطبقة السياسة.

3. الغاية والمساهمة

3.1 الغاية من البحث

عمليًا، وتحديد الفرق بين متطلبات العزل الإلزامية والقرارات MCP Apps قياس حدود الحماية في التي تعتمد على سياسة المضيف، ثم اختبار حل أولي يقلل إساءة استخدام القنوات المسموحة.

3.2 المساهمة المتوقعة

- مجموعة اختبارات قابلة للتكرار تفصل بين اختبارات امتثال المواصفة واختبارات المخاطر المتبقية.
- نموذج أولي لطبقة سياسة على جانب المضيف تتحكم في الروابط والرسائل وتحديث سياق النموذج وتوضح مصدر الواجهة.
- مقارنة قبل تفعيل الطبقة وبعدها من حيث الأمن، واستمرار الوظائف المشروعة، وزمن المعالجة.

ملاحظة الحداثة: القواعد الفردية (قائمة سماح الروابط، الموافقة الصريحة، إظهار المصدر، حدود الحجم والمعدل، سجل التدقيق) هي ممارسة جيدة لا اختراعات. عنصرا الحداثة في هذا العمل هما: (أ) القياس التجريبي للمخاطر المتبقية التي تبقى ممكنة عبر قنوات تسمح بها المواصفة صريحًا، و(ب) علامة حد الثقة المعامَلة كعنصر واجهة قابل للقياس يُقيَّم أثره بدل افتراضه.

4. المشاكل البحثية

4.1 المشكلة الرئيسية

الواجهة عن المضيف، لكنها تسمح لها بطلب عمليات ينفذها المضيف. ولا يوجد MCP Apps تعزل في الأدبيات التي راجعناها تقييم تجريبي بسيط يوضح ما تمنعه المواصفة إلزاميًا، وما قد يبقى ممكنًا عبر القنوات المسموحة، ومدى فاعلية سياسة مضيف إضافية في تقليل هذا الخطر.

4.2 المشاكل الفرعية

- SP1: الحاجة إلى التحقق عمليًا من التزام المضيف بحدود CSP ورؤية الأدوات والموارد.

- SP2: احتمال إساءة استخدام القنوات المسموحة مثل ui/message وui/open-link وui/update-model-context من دون كسر الـ sandbox.
- SP3: الحاجة إلى معرفة هل تقلل طبقة سياسة إضافية السلوك غير المرغوب من دون تعطيل العمل المشروع أو إضافة عبء زمني كبير.

4.3 فرضيات البحث والحل المفترض

المشكلة	الفرضية القابلة للاختبار
SP1	**H1: سيرفض المضيف الملتزم بالمواصفة ورؤية CSP جميع حالات الاختبار المخالفة لـ الأدوات والموارد، ويسمح بحالات الامتثال المشروعة. (SP1)**
SP2	**H2: ستقلل طبقة السياسة المقترحة عدد الإجراءات الحساسة المنفذة دون موافقة، وتمنع انتقال القيمة الاصطناعية عبر قناة غير معتمدة، مقارنة بخط الأساس. (SP2)**
SP3	**H3: ستحافظ الطبقة على نجاح جميع حالات التحكم المشروعة المحددة مسبقًا، ولن يتجاوز وسيط العبء الإضافي لمعالجة الطلب محليًا 20 مللي ثانية. (SP3)**

MUST توضيح سلوك خط الأساس: المضيف الملتزم بالمواصفة في خط الأساس ينفذ متطلبات الـ ui/open-link ورؤية الأدوات والموارد، لكنه لا يصدر مطالبة موافقة إلزامية على CSPالخاصة بالعزل و وفي غياب طبقة السياسة، يُرسل هذه الطلبات ui/update-model-context. أو ui/message أو وفق المعالجة الافتراضية للمواصفة (يفتح الرابط الخارجي، يوصل الرسالة إلى المحادثة، يحدث سياق النموذج). هذه المعالجة الافتراضية هي بالضبط سطح الخطر المتبقي الذي تستهدفه طبقة السياسة.

الحل المفترض: طبقة داخل المضيف تعترض الطلبات الحساسة قبل تنفيذها وتطبق قائمة سماح للروابط، وموافقة صريحة، وإظهار مصدر الواجهة، وحدودًا للحجم ومعدل الطلبات، وسجل تدقيق. تقبل الفرضيات أو ترفض وفق النتائج الفعلية، ولا تفترض الدراسة نجاح الحل مسبقًا.

5. أهمية البحث وأهدافه

5.1 أهمية البحث

يوضح البحث مسؤولية المضيف عند التعامل مع واجهة يقدمها خادم غير موثوق، ويمنع الخلط بين حماية الـ sandbox وحماية سياسات المضيف. كما يقدم اختبارًا ونموذجًا أوليًا يمكن لمطوري مضيفات MCP إعادة استخدامهما.

5.2 الهدف العام

تقييم حدود الثقة في MCP Apps وبناء طبقة سياسة صغيرة على جانب المضيف وقياس أثرها تجريبيًا.

5.3 الأهداف الفرعية

- استخراج المتطلبات الأمنية الإلزامية والقنوات التي تعتمد على سياسة المضيف.
- بناء مختبر محلي وتنفيذ خط أساس موحد وسيناريوهات قابلة للتكرار.
- تنفيذ طبقة السياسة المقترحة وتشغيل السيناريوهات نفسها بعد تفعيلها.
- مقارنة الأمن والوظائف والأداء وقبول الفرضيات أو رفضها وفق النتائج.

6. المنهجية

6.1 نوع الدراسة وتصميمها

تستخدم الدراسة منهجًا تجريبيًا تطبيقيًا داخل مختبر محلي معزول. وتنفذ الحالات نفسها في مجموعتين:

- Baseline: مضيف اختبار يطبق متطلبات MUST في مواصفة MCP Apps، دون طبقة السياسة الإضافية.
- Treatment: المضيف نفسه والبيئة نفسها، مع تفعيل الطبقة المقترحة فقط.

المتغير المستقل هو حالة الطبقة (معطلة/مفعلة). والمتغيرات التابعة هي قرارات السماح والرفض، وتنفيذ الإجراءات دون موافقة، ووصول البيانات الاصطناعية، ونجاح الوظائف المشروعة، وزمن المعالجة.

6.2 بيئة الاختبار ونطاقه

- جهاز Linux واحد وبيئة محلية معزولة.
- مضيف اختبار واحد مبني على basic-host وAppBridge من مشروع ext-apps (Model Context Protocol, 2026a).
- خادم MCP محلي، وواجهة مشروعة، وواجهة اختبار غير موثوقة.
- أدوات وموارد وهمية، وخادم استقبال محلي، وقيمة اختبار مثل SYNTHETIC_SECRET_001.
- سجل موحد لرسائل JSON-RPC وقرارات السياسة والأزمنة.

يُفترض أن المهاجم يتحكم في خادم MCP والواجهة، لكنه لا يملك وصولًا مباشرًا إلى جهاز المستخدم. ولا تشمل الدراسة كسر المتصفح أو الهروب من الـ sandbox أو إجراء تجربة تصيد على أشخاص حقيقيين.

6.3 الحل المقترح

تعترض طبقة السياسة رسائل الواجهة قبل تنفيذها، وتطبق أربع قواعد:

- 1. الروابط: التحقق من مخطط البروتوكول (http/https) وموافقة صريحة قبل فتح الرابط.
- 2. الرسائل والسياق: موافقة صريحة، وإظهار شارة المصدر، وحد أقصى لحجم الرسالة (4 كيلوبايت).
- 3. حد الثقة المرئي: إضافة علامة ثابتة حول الواجهة توضح أنها مقدمة من خادم MCP خارجي.
- 4. التدقيق: تسجيل المصدر ونوع الطلب والقرار وسببه وزمن المعالجة دون تخزين بيانات حساسة.

ورؤية الأدوات جزءًا من امتثال خط الأساس للمواصفة، وليست إسهامًا جديدًا CSP تظل اختبارات للطبقة. والعنصر الجديد المُقيَّم هنا هو علامة حد الثقة المعامَلة كعنصر قابل للقياس والقياس التجريبي للمخاطر المتبقية عبر القنوات المسموحة.

6.4 خطوات التنفيذ

- 1. تشغيل المثال الرسمي والتحقق من عرض واجهة مشروعة واستدعاء أداة مسموحة.
- 2. بناء الخادم المحلي والواجهتين والأدوات والموارد الوهمية وخادم الاستقبال.
- 3. تثبيت حالات الاختبار وتشغيلها في Baseline وتسجيل النتائج.
- 4. تنفيذ طبقة السياسة كوحدة يمكن تشغيلها وإيقافها.
- 5. تشغيل الحالات نفسها في Treatment بالإعدادات والبيانات نفسها.
- 6. مقارنة النتائج واختبار H1-H3 وكتابة الاستنتاجات.

6.5 مصفوفة الاختبار

الاختبار	Baseline (المتوقع)	Treatment (المتوقع)	المقياس
أداة مشروعة ذات	سماح	سماح	الحفاظ على الوظيفة

app وصول			
أداة غير ظاهرة للتطبيق	رفض	رفض	امتثال المواصفة
اتصال إلى نطاق غير معلن في CSP	رفض	رفض	امتثال CSP
فتح رابط خارجي	بلا مطالبة موافقة؛ يُفتح الرابط وفق المعالجة الافتراضية (يُرصد ويسجل)	موافقة ثم سماح/رفض	التنفيذ دون موافقة
ui/message أو تحديث السياق للمضيف	يُوصل بلا مؤشر مصدر (يُرصد ويسجل)	موافقة وإظهار المصدر	سلامة القناة
واجهة تشبه المضيف	تعرض داخل العزل	تظهر معها علامة مصدر ثابتة	وضوح حد الثقة
عملية مشروعة محددة مسبقًا	نجاح	نجاح	الحجب الخاطئ

نحن ندرس ثلاث فئات من القدرات التي يديرها المضيف: (1) فتح الروابط (ui/open-link)، (2) التدقيق (ui/update-model-context)، و(3) الرسائل وتحديث سياق النموذج (ui/message و). وفي ui/message، يضع اختبار التسريب SYNTHETIC_SECRET_001 في جسم والمراقبة. ويتحقق مما إذا كانت تصل إلى خادم الاستقبال المحلي ui/update-model-context حمولة.

6.6 القياس وتحليل النتائج

- عدد اختبارات الامتثال الناجحة من الإجمالي.
- عدد الطلبات الحساسة المنفذة دون موافقة قبل الطبقة وبعدها.
- نجاح أو فشل انتقال القيمة الاصطناعية في كل قناة.
- نسبة العمليات المشروعة الناجحة، وعدد العمليات المحجوبة خطأ.

- اكتمال سجل التدقيق ومتوسط ووسيط زمن المعالجة عند الشريحة المئوية 95.

خطة قبول الفرضيات: تُقبل إذا رفض خط الأساس 100% من حالات مخالفة H1 وعدم ظهور CSP الأدوات وأسمح بـ 100% من حالات الامتثال المشروعة، وإلا تُرفض. تُقبل إذا قللت المعالجة H2 الإجراءات الحساسة دون موافقة إلى الصفر ومنعت انتقال عبر SYNTHETIC_SECRET_001 إذا نجحت جميع حالات H3 وإلا تُرفض. تُقبل ui/update-model-context، وui/message التحكم المشروعة في المعالجة ولم يتجاوز وسيط عبء السياسة المحلي 20 مللي ثانية، وإلا تُرفض.

تشغل كل حالة وظيفية خمس مرات في كل مجموعة. ويُكرر قياس الأداء 30 مرة بعد خمس عمليات إحماء لا تدخل في الحساب. تعرض النتائج بالأعداد والنسب المئوية والمللي ثانية، ثم تقارن بالنتائج المتوقعة في H1-H3. وتمثل 20 مللي ثانية عتبة تشغيلية أولية حددها الباحثون لتقييم النموذج داخل المختبر، وليست حدًا معياريًا في مواصفة MCP Apps.

6.7 الضوابط الأخلاقية والقيود

تُجرى جميع التجارب محليًا باستخدام بيانات وحسابات اصطناعية، ولا تستهدف خدمات عامة أو مستخدمين حقيقيين. تقتصر النتائج على مضيف واحد وثلاث فئات من القدرات؛ لذلك يمثل النموذج إثبات فكرة وليس منتجًا أمنيًا مكتملًا.

7. تنظيم الوقت

مدة تنفيذ البحث ستة أسابيع.

الفترة	العمل الرئيسي	المخرج	التكلفة المباشرة
الأسبوع 1	مراجعة المواصفة؛ تشغيل المثال الرسمي؛ تثبيت خطة الاختبار.	مختبر يعمل وخطة اختبار ثابتة	0
الأسبوع 2	بناء الواجهتين؛ تشغيل	نتائج خط الأساس	0

	حالات Baseline.		
الأسبوع 3	إكمال قياسات خط الأساس وتثبيت سجلاته.	نتائج خط أساس نهائية	0
الأسبوع 4	تنفيذ طبقة السياسة كوحدة قابلة للتشغيل.	وحدة طبقة السياسة	0
الأسبوع 5	تشغيل الحالات نفسها في Treatment.	نتائج ما بعد الحل	0
الأسبوع 6	تحليل النتائج؛ اختبار H1-H3؛ كتابة التقرير.	التقرير النهائي	0

لا توجد تكلفة مباشرة متوقعة؛ لأن الجهاز متاح والأدوات مفتوحة المصدر والتجارب محلية. وإذا ظهرت تكلفة طارئة فستوثق في التقرير الفعلي.

8. المراجع

Bühler, C., Biagiola, M., Di Grazia, L., & Salvaneschi, G. (2026). AgentBound: Securing execution boundaries of AI agents. Proceedings of the 34th ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering. https://doi.org/10.1145/3808103

Debenedetti, E., Zhang, J., Balunović, M., Beurer-Kellner, L., Fischer, M., & Tramèr, F. (2024). AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses in LLM agents. NeurIPS 2024 Datasets and Benchmarks Track. https://arxiv.org/abs/2406.13352

Greshake, K., Abdelnabi, S., Mishra, S., Endres, C., Holz, T., & Fritz, M. (2023). Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security. https://arxiv.org/abs/2302.12173

Hou, X., Zhao, Y., Wang, S., & Wang, H. (2025). Model Context Protocol (MCP): Landscape, security threats, and future research directions. arXiv:2503.23278. https://arxiv.org/abs/2503.23278

Maloyan, N., & Namiot, D. (2026). Breaking the Protocol: Security analysis of the Model Context Protocol specification and prompt injection vulnerabilities in tool-integrated LLM agents. arXiv:2601.17549. https://arxiv.org/abs/2601.17549

Model Context Protocol. (2026a). ext-apps: Specification and SDK for the MCP Apps extension [Source code]. https://github.com/modelcontextprotocol/ext-apps

Model Context Protocol. (2026b). MCP Apps specification (revision 2026-01-26). https://github.com/modelcontextprotocol/ext-apps/blob/main/specification/2026-01-26/apps.mdx

Radosevich, B., & Halloran, J. (2025). MCP safety audit: LLMs with the Model Context Protocol allow major security exploits. arXiv:2504.03767. https://arxiv.org/abs/2504.03767

Salomon, I., Yosef, L., Chafik, O., Swannack, J., Hefner, J., Pidkuiko, A., Cooper, N., Ashley, B., & Christakis, A. (2026). SEP-1865: MCP Apps—Interactive user interfaces for MCP. Model Context Protocol. https://modelcontextprotocol.io/seps/1865-mcp-apps-interactive-user-interfaces-for-mcp